

Server Hardening & Abuse Prevention Guide

For new Ubuntu servers on Hetzner (Docker Compose workloads)

Date: 2025-12-28

Purpose: prevent outbound port scans / abuse reports by applying strong defaults for networking, Docker exposure, patching, and monitoring.

- Applies to: Ubuntu 22.04/24.04, Docker Engine + docker compose, Nginx reverse proxy, Postgres, Node/Next.js apps.
- Outcome: only required ports are exposed, outbound traffic is controlled, suspicious activity is detectable, and incident response is repeatable.

1. What typically triggers an abuse report

Providers flag servers that generate suspicious outbound traffic, such as UDP/TCP scans, brute force attempts, or traffic to many ports/hosts in a short time.

- A compromised application/container running a scanner or botnet client.
- A misconfigured service doing discovery across the internet (rare but possible).
- Leaked credentials allowing an attacker to run commands on the host.
- Exposed services (e.g., databases) used as amplification/relay, or exploited and then used to scan others.

Rule of thumb: treat outbound scanning as a compromise until you prove otherwise.

Quick containment (do this immediately if you receive a notice)

These steps stop further abuse while you investigate. They are safe defaults for most web workloads.

```
# 1) Stop outbound UDP except DNS (53) + NTP (123)
sudo iptables -P OUTPUT ACCEPT
sudo iptables -A OUTPUT -p udp --dport 53 -j ACCEPT
sudo iptables -A OUTPUT -p udp --dport 123 -j ACCEPT
sudo iptables -A OUTPUT -p udp -j REJECT --reject-with icmp-port-unreachable

sudo ip6tables -P OUTPUT ACCEPT
sudo ip6tables -A OUTPUT -p udp --dport 53 -j ACCEPT
sudo ip6tables -A OUTPUT -p udp --dport 123 -j ACCEPT
sudo ip6tables -A OUTPUT -p udp -j REJECT --reject-with icmp6-port-unreachable

# 2) Capture evidence (15-30 seconds each)
sudo ss -uapn | head -200
sudo ss -tpn | head -200
sudo tcpdump -nn -i any udp and not port 53 and not port 123 -c 50
```

Then proceed with the hardening sections below and send a short statement to the provider (template in Section 8).

2. Baseline OS hardening (Ubuntu)

2.1 Patch and reboot policy

- Enable automatic security updates and reboot during maintenance windows.
- Keep the kernel and OpenSSH updated.

```
sudo apt-get update
sudo apt-get install -y unattended-upgrades
sudo dpkg-reconfigure -plow unattended-upgrades
```

2.2 SSH hardening

- Disable password authentication (keys only).
- Disable root login over SSH.
- Use fail2ban to block brute force attempts.

```
# Edit SSH config
sudo nano /etc/ssh/sshd_config
```

```
# Recommended settings:
# PermitRootLogin no
# PasswordAuthentication no
# PubkeyAuthentication yes
# AllowUsers <your_admin_user>
```

```
sudo systemctl restart ssh
```

```
sudo apt-get install -y fail2ban
sudo systemctl enable --now fail2ban
sudo fail2ban-client status
```

2.3 Remove or disable unused services

Every open service increases risk. Keep only what you need.

```
sudo ss -tulpn
sudo systemctl --type=service --state=running | head -120
```

3. Network firewall: safest default rule set

Goal: expose only required inbound ports (usually 22, 80, 443), and restrict outbound traffic to what your apps need.

3.1 Inbound policy (host)

- Allow: SSH (22) from your admin IP range if possible.
- Allow: HTTP/HTTPS (80/443).
- Block: everything else (including public database ports).

```
# Example: allow only 22, 80, 443 inbound
sudo iptables -P INPUT DROP
sudo iptables -A INPUT -i lo -j ACCEPT
sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT
sudo iptables -A INPUT -p tcp --dport 80 -j ACCEPT
sudo iptables -A INPUT -p tcp --dport 443 -j ACCEPT
```

```
# Optional: drop noisy UDP scans to memcached port
sudo iptables -A INPUT -p udp --dport 11211 -j DROP
```

3.2 Outbound policy (egress filtering)

Egress filtering is one of the best defenses against 'your server scanned someone' reports.

- At minimum: block outbound UDP except DNS and NTP.
- Optionally: restrict outbound TCP to only required destinations/ports if you have strict needs.

```
# Persist rules across reboot
sudo apt-get install -y iptables-persistent
sudo netfilter-persistent save
```

If you run email from the server, you may need outbound TCP 25/465/587; otherwise keep it closed.

4. Docker and Compose security (common root cause)

Many incidents are caused by exposing internal services (Postgres, Redis, admin panels) to the public internet via Docker port mappings.

4.1 Do not publish databases to 0.0.0.0

Example risk: mapping Postgres to the internet (e.g., 0.0.0.0:5433->5432). Instead, keep DB internal and connect from app containers.

Recommended docker-compose pattern

```
services:
  nginx:
    ports:
      - "80:80"
      - "443:443"
    networks: ["public", "internal"]

  web:
    expose: ["3000"]
    networks: ["internal"]

  cms:
    expose: ["3000"]
    networks: ["internal"]

  postgres:
    expose: ["5432"]
    networks: ["internal"]

networks:
  public:
  internal:
    internal: true
```

- Use 'expose' for internal-only ports, not 'ports'.
- Put Postgres/Redis on an internal Docker network only.
- Ensure admin dashboards are behind authentication and not publicly accessible.

4.2 Keep Docker itself locked down

- Do not expose the Docker daemon (TCP 2375/2376) to the internet.
- Limit who is in the 'docker' group; it is effectively root.
- Use images from trusted sources and pin versions.

4.3 Container runtime hardening (when feasible)

- Run containers as non-root user.
- Drop capabilities and set read-only filesystem for services that allow it.
- Limit outbound access from containers if you have strict needs (advanced).

5. Monitoring and detection (catch problems early)

5.1 Confirm you are not scanning

```
# No suspicious UDP sockets?  
sudo ss -uapn
```

```
# Watch outbound UDP (should be mostly DNS/NTP)  
sudo tcpdump -nn -i any udp and not port 53 and not port 123 -c 50
```

5.2 Log review shortcuts

```
# SSH logins  
sudo grep -iE "Accepted|Failed|Invalid user" /var/log/auth.log | tail -200
```

```
# System log overview  
sudo journalctl -p warning --since "24 hours ago" | tail -200
```

5.3 Optional: install auditd for command auditing

```
sudo apt-get install -y auditd  
sudo systemctl enable --now auditd
```

For container logs, rely on docker logs and structured app logs shipped off-host (recommended).

6. Incident response playbook (when you get an abuse email)

- Contain: apply egress filtering immediately, and stop suspicious containers/services.
- Investigate: identify process/container responsible; check auth logs; check recent changes.
- Eradicate: patch; rotate secrets; rebuild images; remove unknown users/keys; redeploy clean.
- Recover: re-enable only necessary networking; monitor closely.
- Report: provide a short statement to the provider describing what happened and what you changed.

Finding the source quickly (host + docker)

What is running?

```
sudo ss -tulpn
```

```
docker ps
```

```
docker stats --no-stream
```

Recently modified binaries (suspicious if unexpected)

```
sudo find /usr /etc /opt -xdev -type f -mtime -2 2>/dev/null | head -200
```

If compromise is suspected and you cannot explain it quickly, rebuild the server from a clean image and restore only known-good data.

7. Hardening checklist for every new server

Category	Action	Status
Accounts	Create non-root admin user; disable root SSH; keys-only auth.	TODO
Patching	Enable unattended-upgrades; schedule reboots.	TODO
Firewall (in)	Allow only 22, 80, 443. Block everything else.	TODO
Firewall (out)	Block outbound UDP except 53/123. Persist rules.	TODO
Docker	Only nginx published; DB/internal services not exposed publicly.	TODO
Secrets	Use env files or vault; rotate after incidents.	TODO
Monitoring	fail2ban enabled; log review routine; alerts.	TODO
Backups	Off-host backups; tested restore procedure.	TODO

Tip: Keep this as a runbook in your repo and run it after every fresh provision.

8. Provider statement template (Hetzner abuse response)

Keep the abuse ID unchanged in the subject line. Use the template below in their statement form (or email reply if the portal is unavailable).

Subject: [AbuseID:10E435C:24] (keep unchanged)

We investigated the reported outbound UDP scan from our server.

Immediate containment: we enforced strict egress filtering on the host to block outbound UDP exc

We reviewed running processes/containers and scheduled tasks and are applying OS updates and add
Preventive measures include persistent firewall rules, reduced exposed services (only 22/80/443 p

If the retry/statement portal shows the ticket as closed or unavailable, please accept this stat

Replace the abuse ID and dates as needed.